

Information Gathering & Reconnaissance Assignment

Objective

Demonstrate structured, ethical, and documented reconnaissance against a legally in-scope public VDP or Bug Bounty target. This assignment evaluates analysis and reporting skills, not tool execution alone.

Phase 0 – Scope Verification (Mandatory)

- Select ONE public VDP/Bug Bounty program (HackerOne, Bugcrowd, or Intigriti).
- Include the program URL and copy the exact in-scope section in your report.
- List in-scope assets and explicitly mention out-of-scope assets.
- Choose ONE domain strictly within scope.

Phase 1 – Passive Information Gathering

- WHOIS (domain and IP if resolved).
- DNS and passive subdomain enumeration.
- robots.txt and sitemap analysis.
- Technology fingerprinting (Wappalyzer / WhatWeb).
- Wayback Machine review.
- Email harvesting (theHarvester – passive sources only).
- Google dorking (site:, filetype:, intitle:, inurl:, wildcard subdomains).

Phase 2 – Active Information Gathering (Only If Allowed)

- Host discovery (non-intrusive).
- Basic Nmap scanning and service/version detection.
- Operating system detection.
- WAF detection.
- DNS zone transfer attempt (if permitted).
- NO exploitation, brute force, DoS, or automated vulnerability scanners.

Phase 3 – Analysis & Attack Surface Mapping

- Asset inventory (domains, subdomains, IPs, technologies, open ports).
- Identify potential attack surface areas.

- Explain why findings may present risk.
- No exploitation required.

Deliverable Format

- Executive Summary.
- Scope Verification section.
- Methodology.
- Findings (Passive and Active separated).
- Attack Surface Mapping.
- Ethical Reflection.
- Appendix (tool outputs).

Grading Rubric (100 Marks)

- Scope validation & legality – 15 marks.
- Passive recon depth – 20 marks.
- Active recon discipline – 15 marks.
- Analysis quality – 25 marks.
- Attack surface reasoning – 15 marks.
- Report structure & professionalism – 10 marks.